

FACULTAD DE INGENIERIA
Carrera de Ingeniería de Sistemas



UNIVERSIDAD
CATÓLICA
BOLIVIANA

Tema: Investigación sobre el Marco MITRE ATT&CK

Materia: Etica y Seguridad de Sistemas

Nombre: Luz Karina Ticona Chacon

1. ¿Qué es el Marco MITRE ATT&CK?

MITRE ATT&CK es el acrónimo en inglés de Adversarial Tactics, Techniques, and Common Knowledge. Se trata de una base de conocimiento de acceso público y alcance mundial que documenta tácticas, técnicas y procedimientos (TTP) adversarios fundamentados en observaciones del mundo real (MITRE Corporation, 2025). Su propósito primordial es servir como fundamento para el desarrollo de metodologías y modelos específicos de ciberamenazas en los sectores privado, gubernamental y en la comunidad de productos y servicios de ciberseguridad.

El contenido de ATT&CK se publica en línea y se actualiza generalmente entre dos y tres veces por año, incorporando nuevas técnicas y grupos de amenazas a medida que la comunidad global de investigadores aporta evidencias de ataques reales (SOC Prime, 2025). Esta dinámica de actualización continua garantiza que el marco permanezca vigente como referencia práctica y operativa.

Además, MITRE ATT&CK permite que profesionales de ciberseguridad, investigadores y empresas tengan un lenguaje común para identificar amenazas, analizar incidentes y fortalecer sistemas de protección. El modelo es actualizado constantemente con información basada en casos reales observados alrededor del mundo.

1.1 Comentario Personal

Considero que el marco MITRE ATT&CK es una herramienta muy importante porque permite entender de forma más clara cómo actúan los ciberdelincuentes. Gracias a este

modelo, las empresas pueden prepararse mejor frente a ataques y detectar vulnerabilidades antes de que ocurran incidentes graves.

2. ¿Para qué se Utiliza el Marco MITRE ATT&CK?

El Marco MITRE ATT&CK tiene múltiples aplicaciones prácticas en el ámbito de la ciberseguridad. CrowdStrike (2025) identifica varios casos de uso recurrentes que abarcan desde la inteligencia de amenazas hasta la evaluación de madurez de los centros de operaciones de seguridad (SOC).

2.1 Emulación de Adversarios

Una de las aplicaciones más valoradas del marco es la emulación de adversarios. Los equipos de seguridad pueden usar la información contenida en ATT&CK para simular ciberataques del mundo real, probando la eficacia de las políticas, prácticas y soluciones de seguridad existentes (IBM, 2024). Esta capacidad permite identificar vulnerabilidades antes de que actores maliciosos reales las exploten.

2.2 Inteligencia de Amenazas

ATT&CK permite describir los comportamientos adversos de forma estandarizada, facilitando el seguimiento de actores de amenaza al asociarlos con tácticas y técnicas específicas (ESET WeLiveSecurity, 2019). Este vocabulario común elimina ambigüedades y mejora la comunicación entre equipos de TI, consultores y proveedores al momento de analizar y reportar incidentes.

2.3 Detección y Respuesta a Incidentes

La incorporación del marco a los procesos de respuesta ante incidentes permite a los equipos de seguridad identificar rápidamente las tácticas y técnicas empleadas por

los atacantes durante un ataque (Proofpoint, 2025). Las tecnologías que mapean alertas a identificadores de técnicas ATT&CK reducen el trabajo manual de correlación, posibilitando que los analistas comprendan de inmediato la importancia de un evento y rastreen la conexión entre comportamientos individuales en una intrusión.

2.4 Análisis de Brechas y Evaluación de Madurez del SOC

El análisis de brechas de seguridad compara las prácticas y tecnologías de ciberseguridad existentes de una organización con el estándar actual de la industria. Una evaluación de madurez del SOC analiza la capacidad de este para bloquear o mitigar constantemente las ciberamenazas con mínima intervención manual. En ambos casos, los datos de MITRE ATT&CK proporcionan información actualizada sobre tácticas, técnicas y mitigaciones (IBM, 2024).

2.5 Aplicación en Empresas Líderes

IBM integra MITRE ATT&CK en sus soluciones de seguridad empresarial, incluidas plataformas de analítica de comportamiento de usuarios (UEBA), detección y respuesta extendida (XDR) y gestión de información y eventos de seguridad (SIEM), para actualizar y mejorar las capacidades de detección y respuesta a amenazas (IBM, 2024). Por su parte, Proofpoint alinea su solución Targeted Attack Protection (TAP) con el marco ATT&CK, utilizando múltiples motores de detección —análisis estático y entorno aislado (sandbox)— para identificar contenido malicioso en tiempo real a través del correo electrónico, redes sociales y dispositivos móviles (Proofpoint, 2025).

2.6 Comentario Personal

Pienso que su uso es muy útil porque permite anticiparse a los ataques antes de que causen daños importantes. También me parece interesante que las empresas puedan entrenar a sus equipos utilizando escenarios similares a los ataques reales.

3. Contenido del Modelo

El Marco MITRE ATT&CK organiza las tácticas y técnicas adversarias en matrices que representan los comportamientos de los atacantes en dominios específicos. Su estructura jerárquica facilita tanto el análisis ofensivo como la planificación defensiva (Check Point, 2024).

3.1 Componentes Estructurales

El marco se articula en torno a tres componentes principales:

Tácticas. Representan los objetivos de alto nivel que un atacante busca alcanzar en un momento dado, es decir, el 'por qué' de un ataque. Corresponden a las fases del ciclo de vida de un ataque, tales como acceso inicial, ejecución, persistencia, escalamiento de privilegios, evasión de defensa, acceso a credenciales, descubrimiento, movimiento lateral, recopilación, comando y control, exfiltración e impacto (IBM, 2024).

Técnicas. Representan el 'cómo' los adversarios logran sus objetivos tácticos. Para cada táctica existen múltiples técnicas que describen métodos específicos de ataque, como el phishing (T1566) para acceso inicial o el uso de scripting (T1059) para ejecución de código (Fortinet, 2024).

Subtécnicas. Algunas técnicas poseen subtécnicas que detallan con mayor granularidad el modo en que un adversario puede llevar a cabo una técnica específica. Por ejemplo, la técnica de ataque de contraseña por fuerza bruta puede lograrse

mediante descifrado de hashes (T1110.002), relleno de credenciales (T1110.004) u otros medios (Check Point, 2024).

Adicionalmente, el marco incluye Procedimientos, que describen ejemplos específicos y reales del uso de una técnica por parte de un actor de amenaza concreto, junto con metadatos como permisos requeridos, plataformas afectadas, fuentes de datos para detección, mitigaciones recomendadas y referencias a grupos APT asociados (Tarlogic, 2024).

3.2 Matrices del Marco

La información de ATT&CK se presenta en formato matricial, con columnas que representan tácticas y filas que contienen las técnicas correspondientes (Fortinet, 2024). El marco contempla tres matrices principales:

Matriz Enterprise. Cubre técnicas utilizadas en ataques contra infraestructuras empresariales. Incluye submatrices para Windows, macOS, Linux, infraestructura de red, plataformas en la nube (Azure AD, Office 365, Google Workspace, SaaS, IaaS) y tecnologías de contenedores. Contiene más de 200 técnicas distribuidas en múltiples etapas del ciclo de vida del ataque (Proofpoint, 2025).

Matriz Mobile. Se centra en los ataques dirigidos a dispositivos móviles corporativos, con submatrices específicas para las plataformas Android e iOS. Incluye técnicas de ataque directo sobre el dispositivo y ataques basados en red que no requieren acceso físico al dispositivo (IBM, 2024).

Matriz ICS (Industrial Control Systems). Abarca las técnicas empleadas en ataques a sistemas de control industrial, como maquinaria, dispositivos, sensores y redes

utilizadas en infraestructuras críticas (INCIBE-CERT, 2022). Esta matriz es especialmente relevante para sectores como energía, manufactura y agua.

3.3 Herramientas Complementarias

El ecosistema ATT&CK incluye herramientas de soporte. El ATT&CK Navigator es una aplicación web de código abierto que permite la navegación, anotación y visualización interactiva de todas las matrices del marco (Ciberseguridad.com, 2020). CALDERA, por su parte, es un sistema automatizado de emulación de adversarios que genera planes de ataque utilizando el modelo de ATT&CK (MITRE ATT&CK, 2025).

3.4 Comentario Personal

Me parece que el contenido del modelo está muy bien organizado porque facilita identificar cada etapa de un ataque. Además, dividirlo en tácticas y técnicas ayuda mucho a comprender cómo trabajan los ciberdelincuentes en situaciones reales.

4. Descripción de Equipos

En el ámbito de la ciberseguridad, el Marco MITRE ATT&CK es utilizado por tres tipos de equipos especializados, cada uno con roles y responsabilidades distintas pero complementarias: el Red Team (equipo rojo), el Blue Team (equipo azul) y el Purple Team (equipo morado) (S2 Grupo, 2024).

4.1 Red Team (Equipo Rojo)

El Red Team actúa como atacante simulado dentro de una organización. Su función es evaluar la postura de seguridad ejecutando emulaciones de adversarios reales, utilizando herramientas como Metasploit, Cobalt Strike y plataformas de simulación de phishing (KeepCoding, 2025). En el contexto de MITRE ATT&CK, el Red

Team extrae de la base de conocimiento las técnicas y escenarios de ataque empleados por grupos APT específicos para diseñar campañas de emulación estructuradas y realistas.

MITRE ATT&CK proporciona al Red Team una matriz estructurada con la descripción de tácticas, técnicas y procedimientos que los adversarios utilizan en sus ataques, permitiéndoles simular con fidelidad las técnicas de actores maliciosos reales para comprometer sistemas y redes (S2 Grupo, 2024). La herramienta CALDERA automatiza este proceso de emulación al generar planes de ataque basados en ATT&CK de forma programática (MITRE ATT&CK, 2025).

4.2 Blue Team (Equipo Azul)

El Blue Team es el equipo defensivo de una organización. Su misión es proteger y defender los activos organizacionales de manera proactiva, identificando posibles vulnerabilidades, monitoreando continuamente el entorno y respondiendo a incidentes de seguridad (Ibernova, 2024). A diferencia del Red Team, cuyo trabajo es episódico, el Blue Team opera de forma continua, empleando herramientas como SIEM (Splunk, Elastic Stack), EDR (CrowdStrike, SentinelOne) y firewalls de nueva generación.

En relación con MITRE ATT&CK, el Blue Team utiliza el marco para desarrollar capacidades analíticas de detección basadas en comportamiento. Los Threat Hunters del equipo azul utilizan ATT&CK para guiar la búsqueda de comportamientos que coincidan con tácticas y técnicas conocidas; cuando identifican actividad sospechosa, revisan la técnica para entender el objetivo probable del atacante y anticipar sus próximos pasos (CrowdStrike, 2025). CrowdStrike, una de las empresas líderes en seguridad de endpoints, integra MITRE ATT&CK en su plataforma Falcon para mapear

automáticamente las alertas a identificadores de técnicas, reduciendo el trabajo manual de correlación de los analistas del SOC.

4.3 Purple Team (Equipo Morado)

El Purple Team no es un equipo separado e independiente, sino un modelo de colaboración en el que el Red Team y el Blue Team trabajan conjuntamente de forma simultánea, compartiendo observaciones en tiempo real y verificando de manera conjunta si una técnica de ataque específica es detectada, bloqueada y correctamente reportada (NFlo Tech, 2025). Su nombre proviene directamente de la combinación de los colores rojo y azul, representando la fusión de perspectivas ofensivas y defensivas.

El resultado de un ejercicio Purple Team no es un informe tradicional, sino un incremento medible en la madurez de detección de la organización, técnica por técnica, siguiendo un mapa estructurado de MITRE ATT&CK (NFlo Tech, 2025). Según el INCIBE-CERT (2021), en un ejercicio Purple Team se utilizan la Cyber Threat Intelligence (CTI) y la matriz de MITRE ATT&CK para caracterizar la amenaza, determinar las tácticas y técnicas a emplear y mapear el plan de ejecución tanto para el equipo atacante como para el equipo defensor.

El Purple Team emplea plataformas colaborativas como AttackIQ y SafeBreach, que facilitan ejercicios de validación continua y la integración de los resultados de cada técnica simulada en el ciclo de mejora de los controles defensivos (KeepCoding, 2025).

4.4 Comentario Personal

La evolución desde esquemas estáticos de Red vs. Blue hacia el modelo colaborativo del Purple Team me parece un avance verdaderamente significativo en la madurez de la industria de la ciberseguridad. Considero que el trabajo en equipo es

fundamental en ciberseguridad. La colaboración entre Red Team, Blue Team y Purple Team permite detectar errores y fortalecer mucho más la protección de los sistemas.

Referencias

Check Point Software Technologies. (2024). *¿Qué es el Marco MITRE ATT&CK?* Cyber Hub — Threat Prevention. <https://www.checkpoint.com/es/cyber-hub/threat-prevention/what-is-mitre-attck-framework/>

Ciberseguridad.com. (2020). *Qué es el Marco MITRE ATT&CK y cómo implementarlo.* <https://ciberseguridad.com/herramientas/marco-mitre-att-ck/>

CrowdStrike. (2025). *¿Qué es el marco MITRE ATT&CK?* <https://www.crowdstrike.com/es-es/cybersecurity-101/cyberattacks/mitre-attack-framework/>

Ibernova. (2024). *¿Qué es un Blue Team y el MITRE ATT&CK Framework?* <https://ibernova.com/blog/que-es-un-blue-team-y-el-mitre-attck-framework-la-ciberseguridad-industrial-evolucionada/>

KeepCoding. (2025). *Red, Blue y Purple Team: funciones y diferencias clave.* <https://keepcoding.io/blog/red-blue-purple-team/>

MITRE Corporation. (2025). *MITRE ATT&CK: Adversary Tactics, Techniques, and Common Knowledge.* <https://attack.mitre.org/>